



Universidad Nacional Autónoma de
México
Facultad de Ingeniería



Proyecto Final: Desarrollo de políticas de seguridad

División de Ingeniería Eléctrica
Seguridad Informática Básica
Grupo 2
Semestre 2026-1

Profesor: Mtra. Dulce Campos del Razo

Integrantes del equipo 3:

Camacho Garduño Miguel Angel - 318041188

Escobar Flores Daniel - 318187952

Pozos Hernández Angel -319122907

Rojas Jiménez Claudia Alin - 318026644

Silverio Martínez Andrés - 319254725

Torres Pimentel Obed - 319093166

Fecha de entrega: 1 de diciembre de 2025

Introducción

En la actualidad, las organizaciones dependen de sistemas de información para operar de manera eficiente, segura y continua. Sin embargo, estos sistemas están expuestos a múltiples amenazas que pueden afectar la confidencialidad, integridad y disponibilidad de la información, así como la continuidad de los servicios tecnológicos.

El desarrollo de políticas de seguridad permite establecer lineamientos claros que orientan la protección de los activos tecnológicos, garantizan el uso adecuado de los recursos y reducen los riesgos asociados a fallas, ataques o accesos no autorizados.

Este documento define las políticas fundamentales para la gestión segura de la información, la infraestructura tecnológica y los servicios digitales dentro de la organización, alineándose con prácticas recomendadas y con controles que buscan minimizar riesgos y fortalecer la postura de seguridad.

Propósito

El propósito de esta política es establecer las directrices, responsabilidades y normas que deben cumplir todos los usuarios, colaboradores y áreas relacionadas con el uso, manejo y protección de los activos de información.

Con estas políticas se busca:

- Proteger los recursos tecnológicos contra accesos no autorizados, alteraciones o pérdidas.
- Reducir la probabilidad de incidentes de seguridad mediante controles preventivos, detectivos y correctivos.
- Definir un marco formal para la gestión de riesgos y la respuesta a incidentes.
- Garantizar que la información crítica se mantenga disponible, íntegra y confidencial.
- Promover una cultura de seguridad dentro de la organización.

Alcance

Estas políticas aplican a:

- **Todos los empleados**, colaboradores externos, proveedores, contratistas y usuarios autorizados que tengan acceso a los sistemas o información de la organización.
- **Todos los activos de información**, incluyendo datos, hardware, software, redes, servicios, infraestructura física y lógica, propiedad intelectual y documentación.
- **Todos los sistemas tecnológicos**, tales como computadoras, dispositivos móviles, servidores, redes, aplicaciones, plataformas en la nube y cualquier recurso conectado.
- **Todas las áreas operativas**, administrativas y técnicas que intervengan en el ciclo de vida de la información: creación, almacenamiento, transmisión, procesamiento y eliminación.
- **Todos los entornos**, ya sean internos, remotos, híbridos o en teletrabajo.

Estas políticas son de cumplimiento obligatorio y su incumplimiento puede derivar en sanciones administrativas, suspensión de accesos o acciones legales de acuerdo con normativas internas.

Análisis de Riesgos

El presente análisis de riesgos se basa en la guía NIST SP 800-30 y considera los activos, amenazas, vulnerabilidades y controles existentes en una organización típica de tamaño mediano.

Activos principales identificados

- Información confidencial y crítica del negocio
- Servidores y bases de datos
- Estaciones de trabajo y dispositivos móviles
- Infraestructura de red (routers, switches, firewalls)
- Aplicaciones y servicios en la nube

- Personal y su conocimiento

Amenazas y vulnerabilidades más relevantes

Amenaza	Vulnerabilidad asociada	Probabilidad	Impacto	Nivel de riesgo	Política que lo mitiga
Acceso no autorizado	Credenciales débiles o compartidas	Alta	Alto	Alto	4.1 Control de Acceso
Malware / Ransomware	Falta de antivirus actualizado o parches	Alta	Muy Alto	Muy Alto	4.2 Uso Aceptable más 4.10 Auditoría
Pérdida de información	Ausencia o fallo en respaldos	Media	Muy Alto	Alto	4.6 Respaldo y Recuperación
Phishing e ingeniería social	Falta de capacitación del personal	Alta	Alto	Alto	4.8 Concientización y Capacitación
Ataques de denegación de servicio	Protocolos inseguros o falta de segmentación	Media	Alto	Medio-Alto	4.5 Seguridad en Redes
Robo o pérdida de dispositivos	Dispositivos sin cifrado o bloqueo	Media	Alto	Medio-Alto	4.3 Protección de la Información más 4.9 Seguridad Física
Divulgación intencional	Controles insuficientes o supervisión deficiente	Baja	Muy Alto	Medio	4.1 y 4.3 más Sanciones

Fallo físico (incendio, inundación)	Ausencia de protecciones ambientales	Baja	Muy Alto	Medio	4.9 Seguridad Física y del Entorno
--	--------------------------------------	------	----------	-------	------------------------------------

Los riesgos de nivel Alto y Muy Alto están relacionados principalmente con el factor humano, credenciales débiles, falta de respaldos y ausencia de capacitación. Las políticas definidas en el presente documento mitigan directamente estos riesgos críticos, reduciendo tanto la probabilidad como el impacto a niveles aceptables para la organización.

Enunciados de la política

A continuación se presentan los enunciados generales que regirán la seguridad de la información:

4.1. Política de Control de Acceso

Esta política responde a los riesgos asociados con accesos no autorizados identificados en el análisis NIST 800-30.

- El acceso será otorgado únicamente a usuarios autorizados por rol.
- Autenticación segura obligatoria: contraseñas robustas, MFA, certificados.
- Prohibido compartir credenciales o dispositivos de autenticación.
- Revisión periódica de privilegios.
- Queda prohibido compartir contraseñas, cuentas, tokens o credenciales de acceso entre usuarios, empleados y administradores.
- Los privilegios de los usuarios, empleados y administradores se revisarán y actualizarán periódicamente para evitar accesos innecesarios.

4.2. Política de Uso Aceptable de Recursos Tecnológicos

- Los recursos de TI deben utilizarse exclusivamente para actividades relacionadas con las funciones laborales.

- Se prohíbe instalar software no autorizado o modificar configuraciones sin aprobación del área de TI o administradores.
- Todo dispositivo conectado a la red deberá contar con antivirus, parches de seguridad y configuraciones autorizadas.

4.3. Política de Protección de la Información

- La información clasificada como sensible o confidencial deberá protegerse mediante cifrado, controles de acceso y almacenamiento seguro.
- La transferencia de datos deberá realizarse sólo a través de protocolos seguros como **HTTPS, SSH o VPN**.
- Queda prohibido divulgar información institucional sin autorización de los administradores.

4.4. Política de Gestión de Riesgos

- Se realizará un **análisis de riesgos** anual para identificar vulnerabilidades, amenazas y controles necesarios.
- Todo riesgo debe documentarse y gestionarse mediante acciones de mitigación, monitoreo y seguimiento.
- La implementación de nuevos sistemas deberá incluir una evaluación de riesgos antes de ser puesta en producción.

4.5. Política de Seguridad en Redes

- El tráfico de red será monitoreado y gestionado por sistemas de seguridad como **firewalls**, sistemas de detección de intrusos (IDS/IPS) y segmentación de red.
- Los servicios remotos deberán utilizar protocolos seguros y evitar el uso de protocolos inseguros como **Telnet**.
- El acceso físico y lógico a equipos de red (routers, switches, servidores) estará restringido al personal autorizado como empleadores y administradores.

4.6. Política de Respaldo y Recuperación

- Los empleados y administradores realizarán **backups periódicos** de información crítica (diarios para datos operativos y al menos semanales para información crítica) para asegurar su disponibilidad ante incidentes.
- Las copias deben almacenarse de manera segura (en ubicación externa o cifrada) y probarse regularmente para garantizar su recuperación.
- La pérdida o corrupción de datos deberá reportarse inmediatamente a los administradores.

4.7. Política de Respuesta a Incidentes

- Todo incidente de seguridad debe ser reportado a los administradores de forma inmediata mediante los canales establecidos.
- El equipo responsable deberá investigar, contener, erradicar y documentar el incidente.
- Se establecerán tiempos de respuesta y responsabilidades según la severidad del evento.

4.8. Política de Concientización y Capacitación

- Todos los usuarios y empleados deberán participar en programas obligatorios de capacitación en seguridad de la información.
- Se realizarán campañas de prevención contra **phishing**, ingeniería social y uso seguro de recursos.
- La cultura de seguridad deberá reforzarse de manera continua.

4.9 Política de Seguridad Física y del Entorno

- El personal de seguridad y TI restringirá el acceso físico a instalaciones críticas únicamente mediante controles biométricos, tarjetas o cerraduras electrónicas.
- El área de infraestructura implementará y verificará protecciones ambientales (extinción de incendios, control climático, sistema de alimentación eléctrica ininterrumpida y detectores de inundación).

- Todos los usuarios protegerán dispositivos móviles y medios extraíbles contra robo o pérdida o robo.

4.10 Política de Cumplimiento, Auditoría y Mejora Continua

- El responsable de seguridad coordinará auditorías internas/externas al menos anuales o tras incidentes graves.
- Todos los empleados, colaboradores y proveedores deberán colaborar plenamente en las auditorías proporcionando la evidencia y acceso requerido.
- Los hallazgos generarán planes de acción correctivos y el responsable de seguridad presentará informe anual a la alta dirección.

Sanciones

El incumplimiento de cualquiera de las políticas establecidas será considerado una falta grave y dará lugar a la aplicación de medidas disciplinarias progresivas, de acuerdo con la gravedad de la infracción, el impacto generado en la organización, la intencionalidad y la reincidencia del responsable. Las sanciones se aplicarán a todos los sujetos comprendidos en el alcance (empleados, colaboradores externos, proveedores, contratistas y usuarios autorizados) y serán determinadas por el área de Recursos Humanos en coordinación con el responsable de seguridad de la información y, en su caso, la alta dirección.

Grado de la infracción	Ejemplos de conductas	Sanción típica (primera vez)	Sanción típica (reincidencia o infracción grave)
Leve	Uso de recursos TI para fines personales no autorizados, no reportar pérdida o robo de dispositivo móvil, no actualizar contraseña en el plazo establecido, no completar	Amonestación verbal o escrita	Amonestación escrita más capacitación obligatoria adicional

	capacitación obligatoria		
Moderada	Compartir credenciales de acceso, instalar software no autorizado, conectar dispositivos personales sin aprobación, no reportar un incidente de seguridad menor	Suspensión temporal de accesos (3-15 días) más amonestación escrita	Suspensión temporal de accesos (15-30 días) más suspensión laboral sin goce de sueldo
Grave	Divulgación intencional de información confidencial, desactivación deliberada de controles de seguridad, acceso no autorizado a sistemas críticos, omisión grave que provoque un incidente mayor	Suspensión inmediata de accesos más terminación de la relación laboral o contractual	Terminación inmediata más posibles acciones legales civiles y/o penales
Muy grave / Delito	Conductas que constituyan delito informático (robo o venta de información, sabotaje, introducción de malware con intención maliciosa, etc.) o que generen daño económico o reputacional significativo a la organización	Terminación inmediata de la relación laboral o contractual más acciones legales civiles y/o penales más denuncia ante las autoridades competentes	Terminación inmediata más acciones legales civiles y penales más denuncia ante las autoridades competentes

Glosario y términos

- **Activo:** Es todo con valor para una organización y que necesita protección. Estos incluyen datos, infraestructura, hardware, software, personal y su experiencia, información, servicios, etc.
- **Amenaza:** Cualquier hecho, suceso o acción con la fuerza o poder de materializarse y provocar daño a un recurso tecnológico
- **Análisis de riesgos:** proporciona un bosquejo del sistema en términos de activos, amenazas y controles de seguridad; es decir, es la base para ejercer un control de todas las actividades
- **Ataque:** Aprovechar una vulnerabilidad con el objetivo de obtener algún beneficio económico
- **Backup:** también conocidas como copias de respaldo, permiten evitar pérdidas de información que pueden llegar a ser vitales para el funcionamiento ya sea de una empresa, institución o de un contenido personal.
- **Autenticación:** Capacidad de demostrar que un usuario o aplicación es realmente quien dice ser
- **Confidencialidad:** Garantizar que la información sólo pueda ser entendida por las partes autorizadas, por nadie más
- **Control de Acceso:** Es un elemento esencial de seguridad que determina quién puede acceder a ciertos datos, aplicaciones y recursos, y en qué circunstancias. De la misma forma que las claves y listas de invitados con aprobación previa protegen los espacios físicos, las directivas de control de acceso protegen los espacios digitales. En otras palabras, permiten a las personas adecuadas entrar y mantener a las personas equivocadas fuera.
- **Disponibilidad:** Se trata de la capacidad de un servicio de unos datos o de un sistema a ser accesible y utilizable por los usuarios autorizados cuando éstos lo requieran. También se refiere a la seguridad de que la información pueda recuperarse en el momento que se necesite, es decir, evitar su pérdida o bloqueo
- **Firewall:** Un firewall es un dispositivo de seguridad de red diseñado para monitorear, filtrar y controlar el tráfico de red entrante y saliente basado en reglas

de seguridad predeterminadas. El propósito principal de un firewall es establecer una barrera entre una red interna confiable y redes externas no confiables.

- **Gestión de riesgos:** se refiere a la planeación de las acciones de seguridad para satisfacer las insuficiencias detectadas por el análisis
- **HTTPS:** El protocolo de transferencia de hipertexto seguro (HTTPS) es la versión segura de HTTP, que es el principal protocolo utilizado para enviar datos entre un navegador web y un sitio web. El HTTPS está encriptado para aumentar la seguridad de las transferencias de datos. Esto es especialmente importante cuando los usuarios transmiten datos confidenciales, como al iniciar sesión en una cuenta bancaria, un servicio de correo electrónico o un proveedor de seguros médicos.
- **Integridad:** Verificar si los activos del sistema han sufrido modificaciones, alteraciones, borrado, inserción y, en general, todo tipo de acción que altere la integridad.
- **MAC:** MAC, o control de acceso a medios, es un identificador único asignado a los controladores de interfaz de red (NIC) para su uso como dirección de red en comunicaciones dentro de un segmento de red. Básicamente, es una forma para que los dispositivos en una red se identifiquen entre sí y se comuniquen.
- **Malware:** Acrónimo en inglés de software malicioso, o software destinado a realizar un proceso no autorizado que tendrá impacto sobre la confidencialidad, integridad o disponibilidad de un sistema de información
- **Phishing:** Crear sitios web o emails parecidos a los de sitios, instituciones financieras, agencias gubernamentales o negocios legítimos para engañar a los usuarios y así revelen su información personal o laboral que se utilizará en el robo de identidad
- **Recurso:** Cualquier bien físico, lógico o intelectual que le permite a la organización alcanzar los beneficios esperados de su gestión tecnológica
- **Riesgo:** La probabilidad de que una amenaza se materialice sobre un recurso tecnológico o un proceso de negocio, y el correspondiente impacto que esto tenga sobre la organización

- **TI:** Acrónimo de Tecnologías de la Información, es el proceso de creación, almacenamiento, transmisión y percepción de la información y los métodos de aplicación de dichos procesos.
- **Vulnerabilidad:** Es una debilidad que hace que un recurso tecnológico sea susceptible de un ataque
- **Router:** Conecta varios dispositivos para crear una red, un router conecta varios switches, y sus respectivas redes, para formar una red aún más grande. Estas redes pueden estar en una sola ubicación o en varias ubicaciones. Cuando cree una red de pequeña empresa, necesitará uno o más routers. Además de conectar varias redes, el router también permite que los dispositivos en red y varios usuarios accedan a Internet.
- **SSH:** SSH, que significa Secure Shell, es un protocolo de red de código abierto que se utiliza para acceder y administrar dispositivos de forma remota a través de un programa, así como cifrar la comunicación en una red insegura. Le ayuda a iniciar sesión en otro sistema a través de una red y le permite ejecutar comandos en el sistema remoto. Una vez que haya iniciado sesión, también tiene la capacidad de mover archivos de un sistema a otro y entregar actualizaciones de software y parches a múltiples sistemas.
- **Switch:** un switch facilita el uso compartido de recursos mediante la conexión de todos los dispositivos, incluidas las computadoras, las impresoras y los servidores, en una red de empresa pequeña. Gracias al switch, estos dispositivos conectados pueden compartir información y comunicarse entre sí, independientemente de dónde se encuentren en un edificio o en un campus. No se puede crear una red de pequeña empresa sin switches que vinculen los dispositivos.
- **Telnet:** Telnet, que significa Telecomunicaciones y Redes, es un protocolo TCP/IP que permite a un usuario establecer una conexión remota a un sistema de forma que parezca un sistema local a través de la línea de comandos. Los administradores de red suelen utilizar este protocolo para acceder y administrar dispositivos de forma remota. Telnet solo admite números de puerto conocidos y no puertos dinámicos, así como comunicación en texto plano.

Enlace al video

<https://youtu.be/XHuXvm8ubH8>

Histórico de versiones, actualizaciones y aprobaciones

Versión 1.0 - 14 de noviembre de 2025

Versión 2.0 - 17 de noviembre de 2025

Versión 2.1 - 19 de noviembre de 2025

Versión 2.2 - 22 de noviembre de 2025

Versión 2.3 - 24 de noviembre de 2025

Versión 2.4 - 1 de diciembre de 2025

Fecha de publicación y entrada en vigor

1 de diciembre de 2025, con entrada en vigor el 13 de diciembre de 2025

Versión del documento

2.4

Referencias

Banco Santander, S.A. (s.f.). *Qué es un backup*. Recuperado el 15 de noviembre de 2025, de <https://www.bancosantander.es/glosario/backup>

Campos del Razo, D. (s.f.). *Proyecto final | Desarrollo de políticas de seguridad*. Recuperado el 29 de octubre de 2025, de <https://aulasvirtuales.cuaed.unam.mx/moodle/mod/resource/view.php?id=167107>

Campos del Razo, D. (s.f.). *Tema 3. Servicios y Mecanismos de Seguridad*. Recuperado el 15 de noviembre de 2025, de https://aulasvirtuales.cuaed.unam.mx/moodle/pluginfile.php/671290/mod_resource/content/1/servicios%20y%20mecanismos%20de%20seguridad%202026-1.pdf

Campos del Razo, D. (s.f.). *Tema 4. Vulnerabilidades y amenazas*. Recuperado el 15 de noviembre de 2025, de https://aulasvirtuales.cuaed.unam.mx/moodle/pluginfile.php/757763/mod_resource/content/1/Vulnerabilidades%20y%20amenazas%202026-1.pdf

- Campos del Razo, D. (s.f.). *Tema 5. Análisis y gestión del riesgo*. Recuperado el 15 de noviembre de 2025, de https://aulasvirtuales.cuaed.unam.mx/moodle/pluginfile.php/760537/mod_resource/content/1/Ana%CC%81lisis%20de%20Riesgos%202026-1.pdf
- Cisco Systems, Inc. (s.f.). *¿Qué es un switch en comparación con un router?* Recuperado el 15 de noviembre de 2025, de https://www.cisco.com/c/es_mx/solutions/small-business/resource-center/networking/network-switch-vs-router.html#~introduction
- Cloudflare, Inc. (s.f.). *¿Qué es HTTPS?* Recuperado el 15 de noviembre de 2025, de <https://www.cloudflare.com/es-la/learning/ssl/what-is-https/>
- Fortinet, Inc. (s.f.). *¿Qué es un firewall? Definición y tipos de firewall*. Recuperado el 15 de noviembre de 2025, de <https://www.fortinet.com/lat/resources/cyberglossary/firewall>
- Lenovo México. (s.f.). *¿Qué es Mac?* Recuperado el 15 de noviembre de 2025, de <https://www.lenovo.com/mx/es/glosario/que-es-mac/?srsltid=AfmBOopY9fPzuhuOi3vjof4vW7KPti9RKHoM4UXIAmDsgOyh15IXpLW>
- Lucena, P. (s.f.). *¿Qué es la tecnología de la información?* Recuperado el 15 de noviembre de 2025, de <https://www.cesuma.mx/blog/que-es-la-tecnologia-de-la-informacion.html>
- Microsoft. (s.f.). *¿Qué es Access Control?* Recuperado el 15 de noviembre de 2025, de Seguridad de Microsoft: <https://www.microsoft.com/es-mx/security/business/security-101/what-is-access-control>
- National Institute of Standards and Technology. (septiembre de 2012). *SP 800-30 Rev. 1, Guide for Conducting Risk Assessments*. Recuperado el 17 de noviembre de 2025, de CSRC: <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- Truong, J. (1 de octubre de 2021). *¿Cuál es la diferencia entre Telnet y SSH?* | *HackerNoon*. Recuperado el 15 de noviembre de 2025, de <https://hackernoon.com/lang/es/cual-es-la-diferencia-entre-telnet-y-ssh>